

KC桌面——外资精译

AI时代的网络安全

AI时代的网络安全

前言



图表 1

Nisha Bachani

董事总经理兼合伙人，波士顿咨询公司

印度的BFSI（银行、金融服务与保险）行业一直处于数字和技术应用的前沿。如今，数字渠道已主导银行、保险和资本市场中的大部分客户互动，该行业的运营转型在过去十年中取得了实质性进展。很少有行业能像这样以如此规模、速度和互联密度运作。

在此背景下，人工智能已成为一股决定性力量，从根本上重塑了网络安全攻防两端的格局。它使任何选择采用它的机构都能获得先进的防御能力，同时，也大幅降低了发动复杂攻击所需的成本、技能和时间。曾经需要数月才能完成的漏洞利用窗口，如今以天为单位计算。网络攻击的进攻端首次以快于防御端的速度扩张，攻击者正在部署同样前沿的能力。

由于数据的性质、相关方的复杂网络、以及违规事件将产生的潜在损失，印度BFSI行业面临的这一挑战比几乎任何同行都更为严峻。印度BFSI行业遭受的攻击强度远高于全球市场，生态系统互联性更强，风险正在迅速上升——网络攻击带来的机会成本和损失现在已远超防御规划的投资和努力。虽然AI的应用正在加速，但针对AI的安全控制仍有待完善。策略不能仅仅是增加合规要求，而必须是增强能力、改善治理和控制。

我们很高兴发布这份报告，它是BCG与印度数据安全委员会合作的成果。报告基于对印度及全球CISO（首席信息安全官）的调查、与BFSI行业高级领导者的结构化对话，以及BCG在网络和金融服务领域的广泛经验。

我们的研究表明，印度BFSI的技术基础已经加强，但威胁环境的发展速度已超越这些基础。网络领导者对许多举措仍持审慎态度，并在AI原生防御变得至关重要的同时，合理地保持了“人在回路”的治理模式。然而，仍存在一些结构性差距——涵盖以业务和客户影响视角进行的风险量化、第三方关联的韧性、恢复准备、人才等方面。这些风险需要以协调而非孤立的方式解决。新的运营模式将更加“同步”，网络安全防御需与各利益相关方保持一致，而不仅限于CISO/CIO（首席信息官）。

对于董事会和首席执行官而言，在这一领域的投资将比以往任何时候都更为关键，并将区分出领导者，建立更强的客户信心。在未来十二到十八个月内果断行动的机构，将决定本十年剩余时间的发展格局，并有望在AI驱动的金融体系中占据领先地位。

我们感谢行业领袖们为形成这些观点所提供的宝贵意见，也感谢DSCI的合作使这份报告得以面世。我们期待您的参与，希望您能从中获得启发！

执行摘要（第二部分）

目录

网络安全势在必行：不断升级的威胁与日益凸显的“未知因素”



图表 2

反思我们的现状 全球及印度CISO之声

第22页



图表 3

印度BFSI必须同步强化网络防御的五个战线

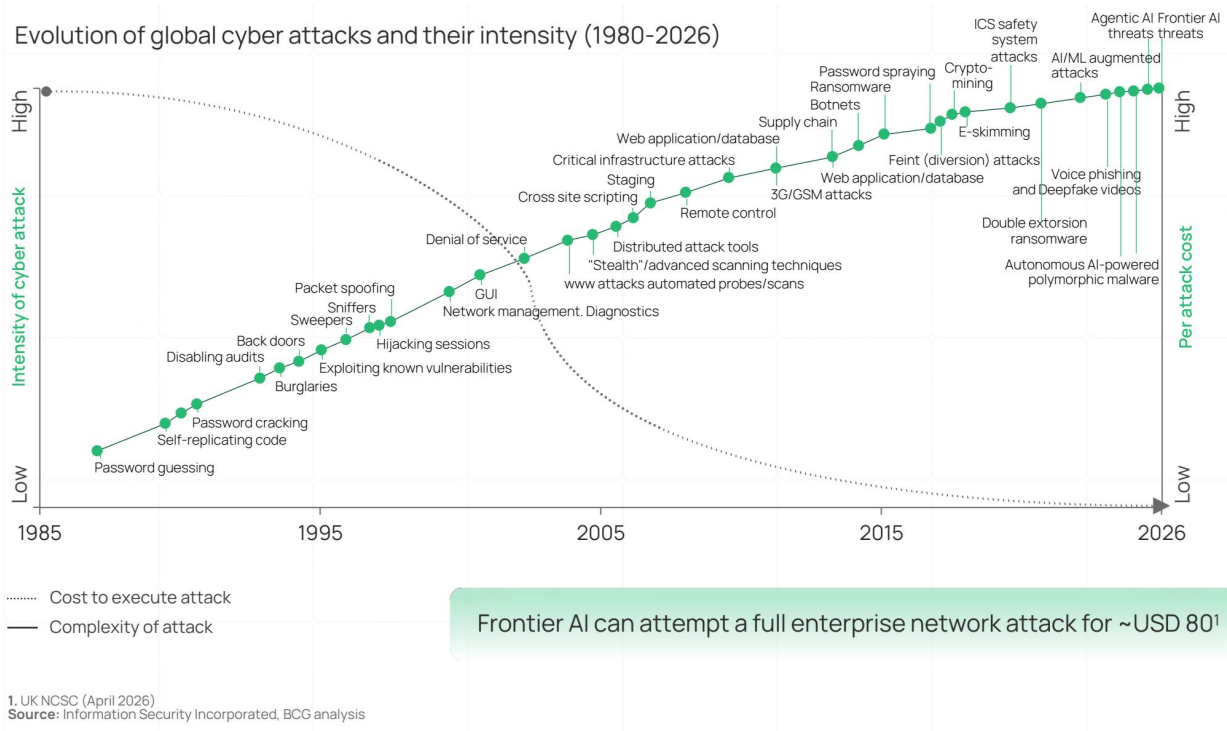
网络安全势在必行：威胁规模升级，“未知因素”日益凸显

- 英国国家网络安全中心（2026年4月）

来源：Information Security Incorporated, BCG分析

前沿人工智能可以约80美元的成本尝试对企业网络进行全面攻击 $\1

网络攻击在过去四十年间不断演变，人工智能正在加速其复杂程度



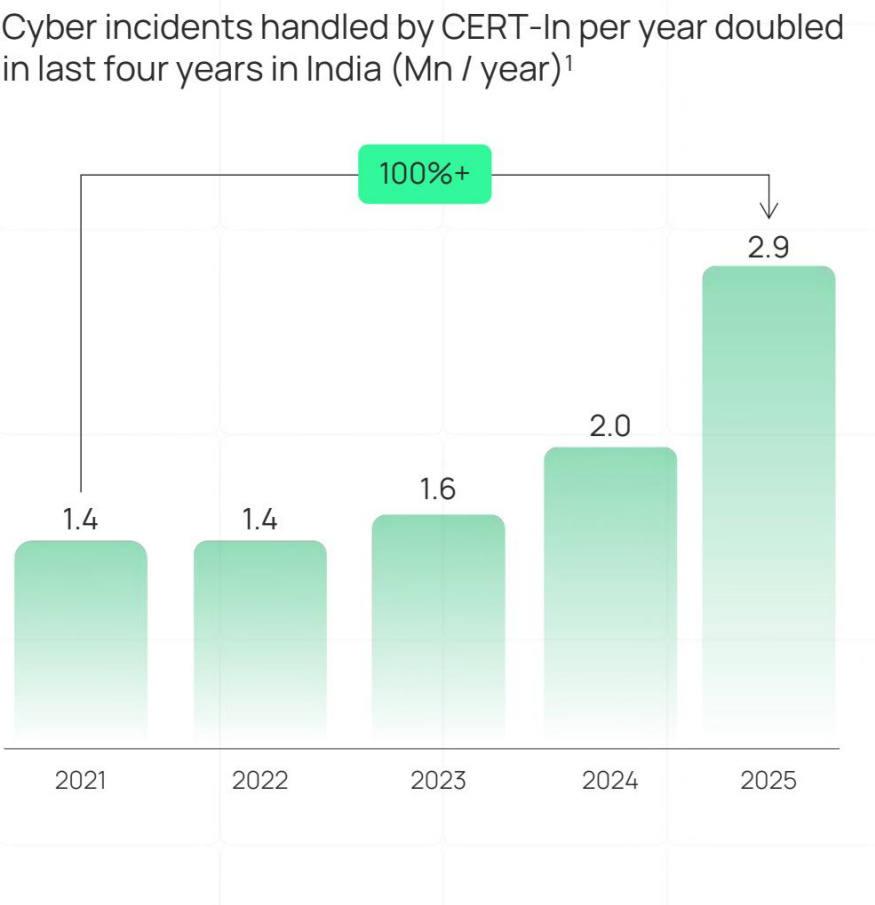
图表 4

印度BFSI行业在应对网络攻击强度方面面临严峻挑战

来源：1. Check Point 网络安全报告 2026（2025年1月 – 2025年12月）；2. IBM 数据泄露成本报告 2025（2024年4月 – 2025年3月）；3. IBM X-Force 威胁情报指数；4. DSCI x Seqrite 印度网络威胁报告 2025/6；5. BCG x GLG 全球首席信息安全官调查 2026，银行与证券 + 保险（不含健康子集）（N=53）；6. BCG x DSCI 印度首席信息安全官调查（N=42）；BCG分析

印度网络事件在过去四年翻倍，BFSI行业遭遇重大入侵

印度CERT-In每年处理的网络事件在过去四年翻倍（百万件/年） $\$^{\{1\}}$



图表 5



图表 6

过去24个月内印度BFSI行业的若干入侵事件

云配置错误导致三大零售券商客户数据泄露（2025年2月） $\$^{4}\$$

由一家领先的全球云服务提供商管理的环境遭到入侵，导致客户数据在暗网泄露；事件发生后市值大幅缩水。



图表 7

共享技术供应商遭勒索软件攻击，导致300家银行服务中断（2024年7月） $\$^{4}\$$

一个勒索软件组织利用了一家共享技术服务提供商中未打补丁的DevOps自动化服务器，扰乱了约300家合作银行和地区农村银行的支付服务。



图表 8

复杂盗窃案从印度最大加密货币交易所之一盗走200亿卢比（2024年7月） ⁵

在一次协同攻击中，一个多重签名钱包被攻破，攻击者被指认为国家支持的黑客组织，资金通过加密货币混合器在全球范围内被洗钱。

印度BFSI行业的中层——中型私营银行、小型金融银行、非银行金融公司、城市合作银行——处于最易受攻击的位置：它们积极进行数字化（因此拥有宝贵的数据和支付通道），并通过共享基础设施深度互联。但其网络安全预算仅为大型机构的零头。

注：CERT-In：印度计算机应急响应小组

- Cert-In 年度报告 2021、2022、2023、2024、2025；3. 《商业标准》（2025年3月3日）；4. 《德干先驱报》（2024年7月31日）；5. 《今日商业》（2025年1月14日）；

来源：新闻稿和文章；BCG分析

八股结构性力量正在推高印度BFSI行业的网络安全风险（I/II）涵盖扩大的攻击面、人工智能驱动威胁及其他结构性问题



图表 9

数字化规模与不断扩大的攻击面

印度的金融攻击面扩张速度超过任何可比经济体。目前超过10亿印度人已上网，拥有6.6亿智能手机用户，这一基数在六年内几乎翻倍。



图表 10

人工智能驱动威胁激增

人工智能工具降低了网络攻击的准入门槛。恶意大语言模型能够实现低成本、高针对性的攻击。攻击者的优势已经转变：利用速度现在超过了防御速度。



图表 11

过度依赖第三方

印度金融机构越来越依赖共享的第三方技术提供商来运营核心业务。单一供应商被攻破可能波及整个链条。



图表 12

遗留系统

运行在延长补丁周期上的遗留核心系统在结构上无法应对更短的利用时间线。遗留系统通常也更容易暴露。

>10亿

到2025年底印度的互联网用户数 $\1

90%以上

人工智能出现后，利用时间缩短的比例 $\2



图表 13

人工智能使攻击成本降低的比例 $\3

50%以上

BFSI行业领导者报告第三方和供应链风险管理仍为临时或被动应对 $\4

低于15%

BFSI行业首席信息安全官对管理无法打补丁的遗留和嵌入式系统有高度信心 $\4

- DataReportal Digital 2026：印度；2. Flashpoint 2026全球威胁情报报告；3. 基于WormGPT年度订阅成本下降的代理指标；4. BCG x DSCI 印度首席信息安全官调查 2026（N=42）

来源：BCG分析

八股结构性力量正在推高印度BFSI行业的网络安全风险（II/II）涵盖扩大的攻击面、人工智能驱动的威胁及其他结构性问题



图表 14

人才稀缺

印度和全球范围内网络安全人才日益短缺，这不仅是由于劳动力数量不足，还因为所需技能与专业知识之间的差距不断扩大。



图表 15

有限的领导层关注与投资

在多家印度金融机构，网络安全被视为IT和合规问题，而非企业级风险。印度BFSI行业的网络安全支出落后于全球同行，进一步拉大了差距。



图表 16

软件可见性瓶颈

由于70-90%的现代软件基于开源库、供应商子依赖项和遗留系统构建，即使是成熟的金融机构也难以维护其运行内容的完整、实时清单。



图表 17

地缘政治格局

每当出现地缘政治热点，国家支持的黑客组织和黑客活动网络的活动便会急剧升级，而BFSI行业与它们攻击的政府和基础设施相邻。

90%以上

印度组织报告存在网络安全人才缺口 $\$^{\{1\}}$

40%以上

BFSI行业高管报告董事会监督、网络安全风险偏好衡量和报告为临时或被动应对 $\$^{\{2\}}$

低于17%

BFSI行业首席信息安全官对第三方和开源依赖项暴露的可见性有高度信心 $\$^{\{2\}}$

150万+

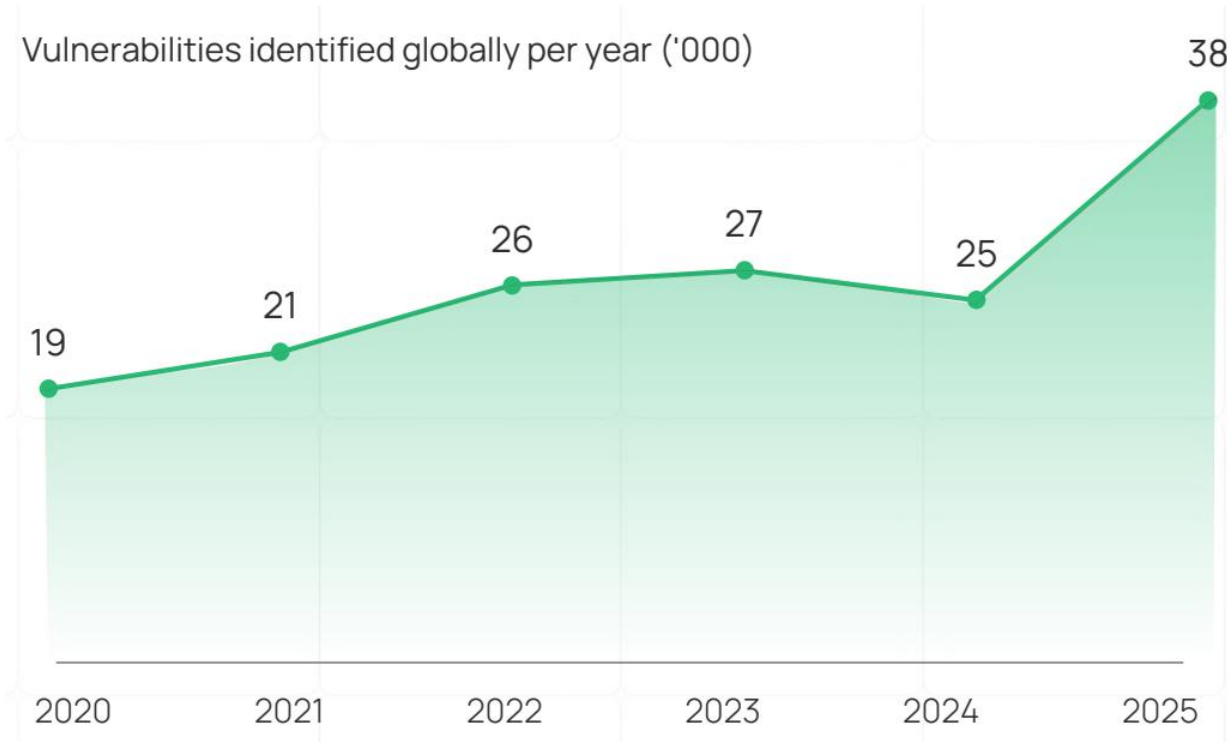
2025年5月地缘政治热点事件后，仅两周内针对印度网站的网络攻击次数 $\$^{\{3\}}$

- DSCI报告 – 印度网络安全产品格局 3.0；2. BCG x DSCI 印度首席信息安全官调查 2026（N=42）；3. 马哈拉施特拉邦网络警察《Sindoor之路》报告

来源：BCG分析

自2024年以来，漏洞披露数量增长了1.5倍，人工智能加剧了威胁

自2020年以来，漏洞披露数量翻倍，过去24个月加速最为显著 $\1



图表 18



图表 19

这些漏洞中，有 $\1 可以在无需身份验证的情况下被利用，显著扩大了攻击面

根据印度高管的说法，人工智能主导的攻击威胁是真实且快速演变的 $\2



图表 20

印度BFSI行业首席信息安全官将人工智能驱动的攻击列为2026年前四大优先事项



图表 21

认为人工智能驱动威胁将在未来12个月内产生重大影响



图表 22

第三方和供应链风险现已成为“第一方”风险——人工智能增加了潜在的入侵风险和影响

供应链风险正成为BFSI行业日益增长的优先事项……

\- 成熟的金融参与者越来越依赖大量的外部全职员工和外包服务（尤其是在云和数据存储领域）

\- 即使某个组织并非攻击的直接目标，由第三方引入的漏洞仍可能对其造成不利影响

- 人工智能增加了利用漏洞和发生数据泄露的风险

...然而，管理这些风险面临着复杂的挑战

1 对第三方供应商及相互依赖关系保持持续可见性

2 按供应商评估风险等级，规模小但高度关联的供应商可能构成重大风险

3 有效管理第三方员工的访问控制



图表 23

在不过度依赖提供商的情况下保障云环境安全

5 加强威胁情报能力，以实现第三方风险的早期发现和快速响应

6 设计具有韧性的流程、服务等级协议和架构，以建立应对第三方风险的运营韧性

7 对攻击进行有效的事件响应管理

55%

印度BFSI行业CXO报告称，第三方及供应链风险是其关注的首要问题^{1}

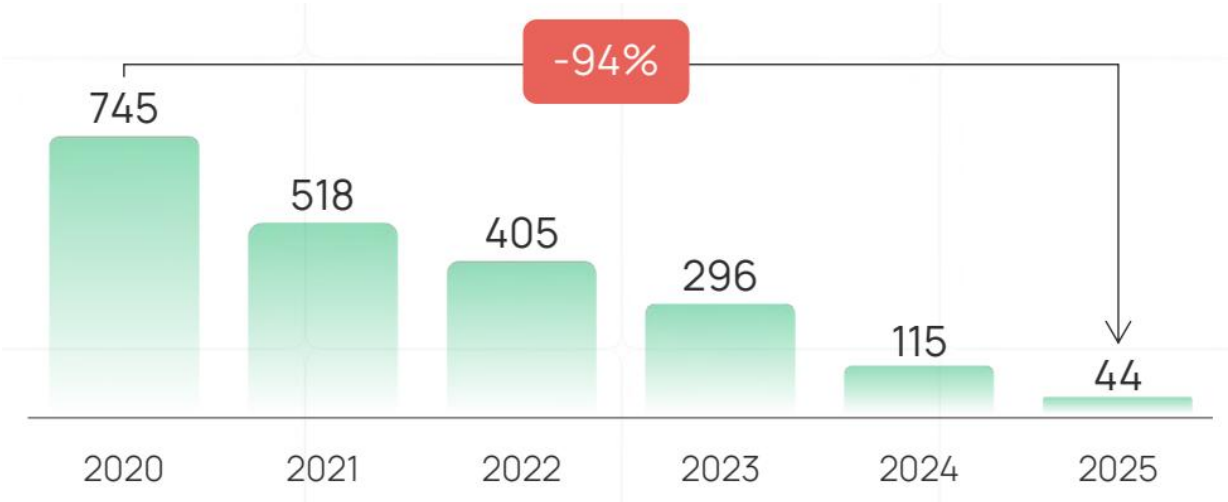
印度BFSI行业的集中度风险已不再是假设性问题——在2024年7月的一次单一事件中，因一家共享供应商被攻破，导致300家银行服务中断。

该领域现在必须从逐个供应商的尽职调查，转向对共享依赖关系进行系统性映射。

攻击经济学正在快速变化——利用漏洞的时间和成本已大幅降低

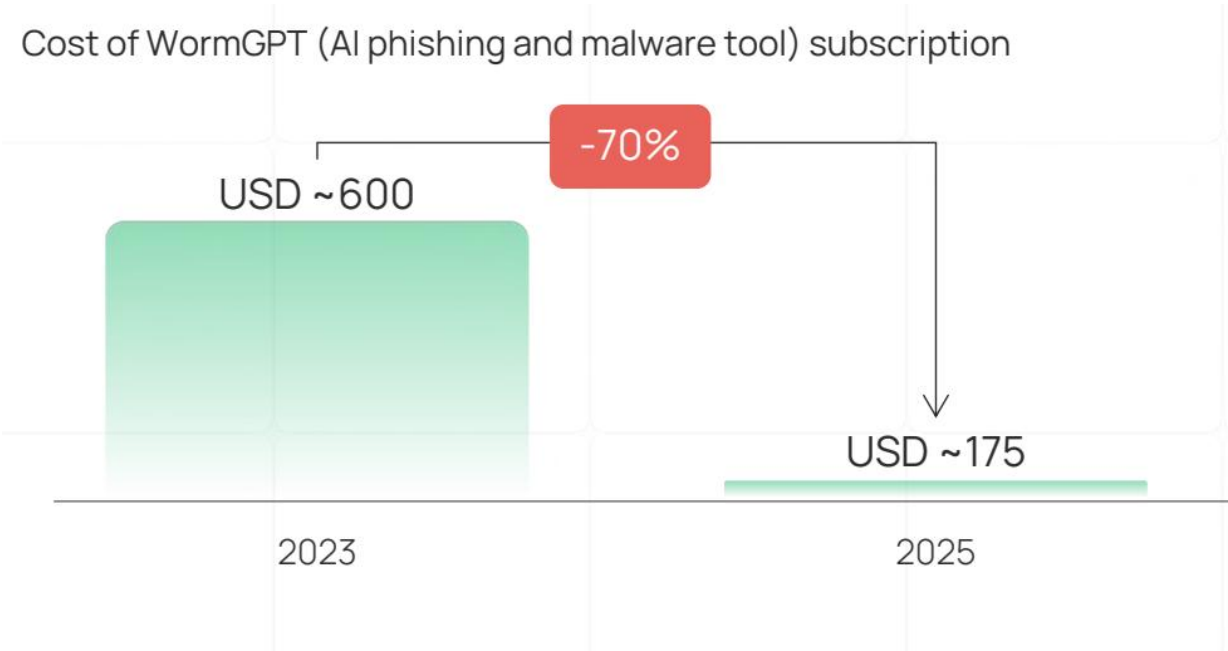
"瓶颈"正在转移——利用漏洞的时间已减少90%以上，大幅压缩了防御方的可用补丁窗口^{1}

从首次披露到被利用的平均天数



图表 24

攻击成本已降低70%以上，使得攻击变得"触手可及"



图表 25

“
虽然现在攻击可以在几天甚至几小时内完成，但我们的变更和补丁管理仍然需要1-3个月。这种速度上的不对称是最大的挑战。

印度中型私营银行首席信息安全官

80美元

前沿人工智能可以尝试以约80美元的成本对企业整个网络发起攻击。 $\2

0.11美元

一个参数量为36亿的小型开放权重模型，运行成本为每百万token 0.11美元，成功复现了FreeBSD漏洞利用。
 $\3

- Flashpoint 2026年全球威胁情报报告；2. 英国国家网络安全中心（2026年4月）；3. AISLE研究（2026年4月）
来源：BCG分析

示例 I 新兴前沿AI模型现在能够以极低成本发现存在27年之久的零日漏洞

高度自信（经过测试、验证、可靠） 不自信至部分自信

印度BFSI行业领导者对应对AI驱动网络事件的准备情况信心有限

对抵御AI驱动攻击的控制措施和运营能力的信心

问：如果贵组织在未来6个月内遭受严重的AI驱动网络事件攻击，您对以下各项控制措施和运营能力能够经受住考验的信心程度如何？

印度BFSI行业的网络防御体系是为应对人类速度的威胁而构建的，尚未经过AI驱动对手的考验，并且在许多情况下，其影响仍是未知数。

需要更好地量化AI驱动事件的恢复时间目标、恢复点目标以及真实的爆炸半径。

网络安全人才是关键制约因素，人工智能进一步拉大了高级技能差距

全球概况

480万

2024年全球未填补的网络安全职位，同比增长19%，远超0.1%的活跃劳动力年增长率 $\wedge{1}$

95%

的网络安全专业人士报告其所在组织至少存在一项已识别的技能缺口 $\wedge{3}$

83%

的全球银行业领导者报告在寻找所需网络安全人才方面面临挑战 $\wedge{2}$

88%

的组织因技能短缺而至少经历过一次网络安全事件 $\wedge{3}$

印度概况



图表 26

人才获取仍是挑战，网络安全岗位（如AI安全、云安全、威胁情报和事件响应）的需求超过供给



图表 27

印度超过95%的组织报告存在网络安全人才缺口 $\wedge{4}$



图表 28

网络安全招聘仍严重依赖外部人才（约45%）。年轻专业人才的学习曲线陡峭，相关课程有限，尤其是在AI时代的网络安全领域

网络安全产品公司目前雇佣了超过6万名网络安全专业人员 4 ，并计划每年增长25%。尽管印度已成为增长最快的人才库之一，但仍可能不足以满足需求，尤其是在AI时代

管理攻击带来的重大业务影响和成本

与防御投入相比，组织风险和损失显著更高

4家欧洲主要银行

25亿美元

英国因生产中断5周造成的经济损失

4亿美元

因在线销售暂停46天造成的损失

4次

约700万条

服务中断天数

消费者记录被泄露

6亿美元

从跨链DeFi桥中被盗

第三方服务提供商遭攻击后，客户的个人身份信息被泄露

影响往往在成为头条新闻之前就已显现。差距不在于认知，而在于量化。

董事会层面的责任具有深远影响——领导者已采取包括辞职在内的重大举措

印度BFSI董事会需要学会用业务影响的语言来衡量网络风险。

总裁兼首席执行官

首席执行官

联席董事长

首席执行官

首席执行官兼首席财务官

必须采用结构化的风险量化方法，建立强大的网络韧性和风险管理能力

- 静态应用安全测试/动态应用安全测试；2. Web应用防火墙；3. 端点检测与响应；来源：BCG分析

以AI防御AI：需要在网络架构中实施强大的AI驱动安全控制措施

非详尽列表

缩小攻击面

\- 增强攻击面管理：发现面向互联网的资产、影子IT和供应商的真实网络暴露面

\- 针对业务逻辑漏洞的代码库测试：使用AI测试来发现传统SAST/DAST \$^{\{1\}}\$ 和WAF \$^{\{2\}}\$ 无法捕捉的利用路径

\- 漏洞优先级排序：根据业务影响、资产关键性和可利用状态对补丁队列进行风险排序，聚焦于那1-2%的关键漏洞

\- 影子AI检测：持续检测和监控未经授权的GenAI使用及数据外泄

强化身份管理

\- 微分段：在工作负载和API边缘实施身份感知、机器学习调优的微隔离，以遏制入侵蔓延

- 非人类身份治理：发现、界定并撤销AI代理、服务账户、API密钥和子代理凭证

\- 加强补偿性控制：对于无法立即修补的漏洞，强化虚拟补丁、配置加固、访问限制、EDR \$^{\{3\}}\$ 调优和加强监控等控制措施

\- AI代理运行时护栏：通过基于AI的运行控制，实时监控自主代理的操作、权限和数据访问

切断攻击路径

- 自主隔离（AI安全运营中心）：通过高置信度的机器学习检测，触发自动隔离、凭证重置和配置回滚

\- 横向移动检测：通过机器学习检测凭证滥用、权限提升和东西向流量中的异常行为

\- 行为分析与自适应认证：通过基于机器学习的用户行为模型检测偏差，并触发增强认证

\- 补丁升级至AI速度：利用实时资产清单、持续漏洞扫描和威胁情报，实现补丁与修复的自动化

关于我们定位的反思：全球与印度首席信息安全官之声

塑造2026年印度BFSI网络安全领域的五大主题

76%的BFSI首席信息安全官将AI驱动的攻击列为首要关切，监管复杂性与生态系统风险紧随其后

塑造印度BFSI议程的网络安全优先事项

问：作为网络安全领导者，您重点关注的首要问题/挑战是什么？（选择前4项）

第一层级 定义网络议程

影子AI与未经授权的工具使用

第二层级 结构性生态系统风险

第三方与供应链网络风险

监管复杂性

第三层级 新兴与运营风险

数据隐私与主权

云安全

勒索软件韧性

来源：BCG x DSCI 印度首席信息安全官调查 2026 (N=42)；BCG分析

为何重要

首要关切在结构上资金不足

76%的首席信息安全官将AI驱动的攻击列为其前四大关切，但仅有19%为此将网络预算增加超过10%。

生态系统层面的风险超过任何单一攻击向量

第三方风险（55%）、身份与AI代理访问（50%）以及影子AI使用（38%）共同表明，首席信息安全官正在优先考虑相互关联的运营与生态系统漏洞，而非直接攻击。

网络成熟度与支出 I

70%以上在数据保护与监控方面具备成熟能力，而治理与第三方风险则落后

印度BFSI关键网络安全实践的成熟度水平 问：以下哪项最能描述贵组织各项网络安全实践的状态？

来源：BCG x DSCI 印度首席信息安全官调查 2026 (N=42)；BCG分析

监管驱动的成熟度 调查结果显示，数据保护是最成熟的网络安全能力——79%的企业将其运行在“活跃”或“持续”成熟阶段。受监管压力时间最长的领域显示出最高的成熟度。

第三方风险是结构性缺口

仅有49%的企业在第三方与供应链风险方面达到成熟实践，而威胁演化的速度已超过现有控制措施。鉴于印度BFSI广泛的第三方风险敞口，这成为一个关键关切领域。

网络成熟度与支出 I

AI威胁正在重塑网络投资优先事项，但印度BFSI的预算扩张仍保持克制

AI主导增量支出，但绝对预算仍有提升空间

问：基于AI的威胁兴起是否影响了您的网络支出？

“总体而言，我不会说我的预算在大幅增加。增幅每年大约只有10%。”

——印度领先中型私人银行首席信息安全官

增量支出偏向AI驱动的安全工具与现有供应商

问：随着未来12个月网络安全支出增加，您预计将如何分配？（多选）

AI驱动的安全工具成为印度BFSI首席信息安全官增量支出的首要优先事项

“大部分安全支出都用于满足合规要求——这留给能力建设的空间有限。”

——印度领先寿险公司首席信息安全官

表示AI威胁已影响网络支出，而全球BFSI这一比例为74%，但网络支出占技术支出的百分比低于全球同行

来源：BCG x DSCI 印度首席信息安全官调查 2026 (N=42)，BCG x GLG 全球首席信息安全官调查 2026，银行与证券+保险（不含健康）子集 (N=53)；BCG分析

AI与网络安全在三个方面交汇——每个方面都需要全面的行动计划

AI的安全性

79%

在过去12个月内正式评估过AI模型安全风险（提示注入、模型投毒、训练数据投毒等）

43%

将AI嵌入企业工作流列为基于AI攻击的首要驱动因素

构建者

AI应用与技术的使用创造了新的网络与数据隐私风险来源，扩大了数字攻击面

抵御AI攻击

攻击者

AI是黑客工具包的一部分，加速并商品化了攻击

防御者

为跟上威胁步伐并应对新的攻击面，组织正在部署AI驱动的网络能力

用于安全的AI

83%

正在积极将AI解决方案嵌入其运营，其中67%将在未来12个月内投资AI解决方案

69%

正在认真探索或积极部署基于AI的安全运营中心到其运营中

76%

将AI驱动的攻击列为2026年的前四大优先事项

来源：BCG x DSCI 印度首席信息安全官调查 2026 (N=42)；BCG分析

69%

认为AI驱动的威胁将在未来12个月及以后对其组织产生重大影响

抵御AI攻击 I 69%的印度首席信息安全官高度关切AI驱动的网络攻击

对AI驱动网络威胁的关切程度

问：对于未来12个月内针对贵组织的基于AI的网络攻击的增加，您有多关切？

的印度BFSI首席信息安全官对未来12个月内基于AI的网络攻击感到“非常”或“极度”关切

行业之声

“

复杂性的增长

现在市场上的这类技术，它产生的攻击路径，只需要一个突破口就能利用。攻击路径会自行定义。如果你的门是开着的，这类技术就会找到进入的方法。

——印度领先资产管理公司

五个关切级别的分布

“

速度的增长

以前我们谈论网络攻击需要100天来侦察和行动。然后是50天。然后是30天。直到去年，是四到五天。今天，如果这些[AI]工具被有效利用，你存在漏洞，就会立即被利用。

——印度领先私人银行首席信息安全官

来源：BCG x DSCI 印度首席信息安全官调查 2026 (N=42)；BCG分析

抵御AI攻击 I AI驱动的社会工程与身份攻击现主导BFSI威胁议程

印度推动防御投资的顶级AI驱动攻击场景 问：您担心/正在积极建设能力以应对哪些类型的安全事件/攻击？

64% AI/深度伪造社会工程 合成语音/视频、AI个性化商业电子邮件欺诈

50% 身份/凭证攻击 凭证填充、令牌窃取、多因素认证绕过

50% 第三方/供应链入侵 供应商入侵、恶意依赖

45% 通过生成式AI工具使用的数据泄露 敏感数据流向外部AI工具、检索增强生成配置错误、影子AI

45% 传统社会工程 网络钓鱼、商业电子邮件欺诈、借口

来源：BCG x DSCI 印度首席信息安全官调查 2026 (N=42)；BCG分析

AI驱动的威胁现已主导印度BFSI的防御优先事项。深度伪造社会工程与生成式AI数据泄露共同标志着从“ AI作为未来威胁 ” 向“ AI作为当前防御优先事项 ” 的转变。拒绝服务攻击，历史上是印度银行业的主要关切，已降至17%，被这些较新的威胁所取代。

5/8

一家<全球超大规模云服务商>[已脱敏]披露了169个漏洞。假设其中50个适用于我横跨5000项资产的平台——那就是25万个已识别漏洞。补丁修复速度已超过修补能力。

首席信息安全官

针对AI的安全防护

在漏洞防御方面，第三方盲点是最薄弱的环节——仅45%的人有信心诊断风险

针对前沿AI识别漏洞的信心水平（印度）

问：如果一项前沿AI能力被用来披露贵组织所依赖的软件中大量涌现的高严重性漏洞，您对以下各项的信心程度如何？

第三方/开源依赖项可见性

分类和严重性评估速度

补丁部署速度

补丁不可用时的补偿性控制措施

来源：BCG x DSCI 印度CISO调查 2026年（N=42）；BCG分析

印度BFSI行业在补丁不可用时对补偿性控制措施信心最强（62%有信心）——这是多年运营遗留系统所锻炼出的能力——但在了解其系统实际依赖哪些第三方代码方面信心最弱（45%有信心）。

这意味着：印度BFSI行业在预测哪些披露会对其造成冲击方面准备不足。

用于AI的安全防护

领先金融机构在AI采用方面与全球同行持平，但60%仍处于试点阶段或以下

组织在AI采用方面的成熟度水平

问：您如何描述贵组织在跨业务职能采用AI（包括生成式AI和智能体AI）方面的整体成熟度？

来源：BCG x DSCI 印度CISO调查 2026年（N=42），BCG x GLG 全球CISO调查 2026年，银行与证券 + 保险（不含健康险子集）（N=53）；BCG分析

底部的差距 更多印度企业落后

60%

印度BFSI处于试点或以下 vs 全球BFSI：43%

顶部的差距 领先企业已迎头赶上

19%

印度BFSI处于广泛部署和显著渗透 vs 全球BFSI：20%

这一差距反映了出于网络风险考量的审慎态度。它今天保护了机构，但一旦规模化加速，风险敞口就会增加

来源：BCG x DSCI 印度CISO调查 2026年（N=42）；BCG分析

用于AI的安全防护 24%的印度BFSI企业尚未正式评估任何重大AI安全风险

企业已评估的AI模型安全风险

问：在过去12个月中，贵组织正式评估了以下哪些AI模型安全风险？（多选）

方法：百分比代表报告在过去12个月内对每项AI模型安全风险进行正式评估的组织比例。"尚未正式评估任何项"反映受访者表示未对所列AI风险类别进行任何正式评估活动。多选回答；百分比之和不为100%。

行业声音

“

[前沿AI威胁]目前炒作成分很大。我们尚未看到组织因此受到影响。

“

每家银行都有第三方风险管理政策。但最近发生的事确实动摇了这一部分。供应链是网络安全中最薄弱的环节之一，这一点我们都清楚。

用于AI的安全防护 不到三分之一的印度BFSI企业已大规模部署核心AI安全控制措施

印度BFSI行业AI安全能力的采用情况

问：贵组织正在积极运用以下哪些能力来保护AI系统、AI智能体或非人类身份？（前两项：已部署 + 试点中）

影子AI监控
密钥管理和令牌轮换
提示注入/模型滥用检测
正式AI治理流程
AI智能体监控与日志记录
非人类身份清单与治理

来源：BCG x DSCI 印度CISO调查 2026年（N=42），BCG x GLG 全球CISO调查 2026年，银行与证券 + 保险（不含健康险子集）（N=53）；BCG分析；方法：百分比代表报告AI安全能力已投入生产或处于试点/概念验证阶段（"前两项"）的组织比例。全球基准反映报告能力已在使用或试点阶段的组织比例。由于全球基准中BFSI样本量有限，使用跨行业全球样本作为比较基线。

与全球差距最大的领域
正式AI治理 印度24% / 全球73%
AI智能体监控 印度21% / 全球60%
智能体行为护栏 印度24% / 全球51%

用于AI的安全防护 仅29%的印度BFSI企业同时拥有AI安全负责人和明确的AI政策

AI安全负责人--

有负责人
AI智能体政策
有政策
无负责人
无政策
0%
33% 真空地带
29% 成熟型
38% 有负责人但无政策规则

“

采用变得非常迅速。首先是业务部门说：'大家都在做，我们也得做点什么。'所以没想太多，他们就开始使用遇到的任何AI。治理尚未建立，而与此同时使用已经遍地开花。
首席信息安全官，印度领先资产管理公司

关键点

- 有责任但无规则是主导运营状态（38%）。组织应优先建立正式的AI治理框架和政策护栏。

\- 结构性风险敞口仍然显著。"无负责人、无政策"群体（33%）加上"有负责人但无政策"群体（38%），合计71%的印度BFSI组织缺乏这两项基础性AI治理要素。

用于安全的AI

对于超过50%的印度CISO而言，速度和自动化正成为采用AI用于安全的主要驱动力

在网络安全中采用AI/ML的原因

问：贵组织在网络安全职能中采用AI/ML的主要目标是什么？

更快的威胁检测， 缩短平均检测时间 和平均响应时间

自动分类和告警丰富

大规模欺诈检测

AI用于安全的投资回报率指标

问：您如何衡量或预期衡量AI赋能网络安全投资的回报率？

平均检测时间和平均响应时间的缩短

已确认事件或违规数量的减少

成本规避：欺诈和违规成本

7%对网络安全中的AI/ML没有正式目标

12%没有计划衡量AI用于安全的投资回报率

用于安全的AI 60%的印度BFSI企业正在将AI嵌入核心检测与响应运营

印度BFSI行业中AI嵌入网络安全运营的领域

问：AI如何被嵌入您的网络安全运营和架构中？（多选）

将AI分析集成到SIEM/SOAR中用于实时威胁关联

利用AI进行欺诈检测和金融犯罪调查

在网络、终端和云环境中嵌入AI驱动异常检测

使用AI自动化漏洞优先级排序和补丁管理

将AI治理控制作为安全架构的核心组成部分实施 尚未转型；架构审查目前已在路线图中 来源：BCG x DSCI 印度CISO调查 2026年（N=42）；BCG分析 方法：数据来自单一多选调查问题；多选百分比之和不为100%

机遇所在

零信任与欺诈检测部署不足

尽管兴趣浓厚，但仅有 40% 的组织报告已积极部署 AI 增强的零信任或欺诈检测能力。

漏洞与异常自动化仍处于早期阶段

AI 主导的漏洞优先级排序和异常检测仍处于早期阶段，仅有三分之一的公司报告已积极部署。

AI 用于安全 I 71% 的印度 BFSI 公司已达到 AI 辅助 SOC 成熟度或更高水平

印度 BFSI 在 SOC 成熟度阶梯上的位置

问：您如何评估贵组织当前对“未来 SOC ”运营模式的采用情况？（单选）

第4级 完全自主、自治的 SOC

第3级 信任自主决策

第2级 部分自动化 / AI 辅助 SOC 第1级 基本标准化，自动化有限 未使用任何这些运营模式

自主 SOC 是理想，但它更像是一个 WordPress 的东西：打包出售。它更多是销售术语而非现实。我们只信任 AI 处理低关键性项目。

印度领先寿险公司 CISO

AI 代理能否自主处理 SOC 分析师工作？

问：在未来 2-3 年内，您预计第一级和第二级 SOC 分析师工作中有多大比例将由 AI 代理自主处理？

第一级：告警分类、初步调查

- 55% 的 CISO 预计 AI 代理将处理超过 25% 的第一级工作
- 24% 仍预计自动化程度低于 10%

第二级：事件关联、升级决策

- 54% 的 CISO 预计 AI 代理将处理超过 25% 的第二级工作
- 21% 仍预计自动化程度低于 10%，信任差距比预期要小

我们已经着手部署自主 SOC。那是从一次真实事件中吸取的教训

印度公共部门银行 CISO

来源：BCG x DSCI 印度 CISO 调查 2026 (N=42)；BCG 分析 方法论：分析反映了未来 12 个月内各网络安全解决方案类别的预期供应商策略。结果按显示的四个响应选项展示，排除了“不知道 / 不适用”选项。类别按整体整合意向排序。

平台整合 I 印度 BFSI 倾向于平台整合，扩张重点在于发展 AI 时代能力

未来 12 个月的网络安全策略，按解决方案类别划分

问：对于以下 12 个网络安全解决方案类别中的每一个，您未来 12 个月的策略是什么？

关键点

- CISO 正在积极整合两个因监管和 AI 推动而变化的类别：IAM（45%）和数据安全（41%）整合到各自单一的主要平台上。
- CISO 正在积极精简 SOC 技术栈：SIEM/SOAR 的合并整合意愿最高，达 61%（38% + 23%），这由 SIEM 市场整合和自主 SOC 的数据平面需求驱动。
- CISO 已在两个平台竞争已在先前周期中胜出的类别完成整合：端点（46% 无变化）以及网络与边缘（43% 无变化）反映了成熟的单一供应商技术栈。

平台整合 I BFSI 的 CISO 为集成而整合，而非为降本——提高了供应商相关性的门槛

印度 BFSI 的 CISO 进行整合的原因

问：对于您打算整合的工具，您这样做的首要原因是什么？（单选）

更紧密的集成/统一视图

CISO 正在整合以减少碎片化，并提高跨安全运营的跨域可见性。

2

减少工具和供应商数量

工具泛滥正在造成运营复杂性，使得简化供应商成为安全团队的优先事项。

3

降低成本

成本仍是一个考虑因素，但在整合决策中，其重要性次于集成和运营效率。

关键点

- 更紧密的集成成为整合的首要原因，领先于减少工具和节省成本。
- 减少工具和供应商的推动力反映了碎片化安全栈、告警疲劳和集成开销日益增长的负担。
- 为印度 BFSI 提供解决方案的供应商必须展示与现有技术栈的无缝集成、可衡量的运营效率以及强大的合规一致性。点解决方案需要清晰的互操作性故事才能保持相关性。

印度 BFSI 必须同步的五个战线 以构建更强的网络防御

同步势在必行

同步是 AI 时代网络安全的运营模式

构建同步化企业的五个战线

实现与业务同步的关键行动

采用董事会批准的网络风险偏好声明，明确货币损失容忍度，并在关键业务服务、产品、渠道和客户旅程层面定义，而不仅仅是在企业层面。

量化网络损失敞口，并根据量化的网络损失容忍度设定明确的风险加权资本储备。

将年度网络报告从控制覆盖范围重新定义为避免的业务损失，并将网络风险与信用风险、市场风险和操作风险一同纳入企业风险仪表盘。

将每个数字发布关口与量化和衡量的网络风险评分挂钩，并在批准前将网络损失容忍度纳入产品级业务案例。

优先处理“高风险”业务领域——识别那些损害可能对业务造成严重影响的有限组件集，并与业务发布同步创建安全更新的能力，以避免风险敞口。

支柱 2

让网络成为跨职能的管理体系，而非 CISO 的工作负担

实现跨职能同步的关键行动

设立由 CEO 主持的网络韧性小组，明确业务、技术、风险、法律、合规、运营和沟通部门的决策权。

运行一次 CXO 级别的网络极端事件模拟，使用非脚本场景，并将每个失败的决策或不明确的所有权转化为可追踪的修复积压工作。

将安全负责人嵌入每个业务部门，将网络素养融入业务部门，并设定业务、技术、风险、法律、运营部门的共享跨职能 KPI。

为产品发布、云接入、补丁例外、AI 用例、违规响应以及监管或客户沟通定义企业级 RACI。

为网络韧性和重大漏洞事件管理制定包含企业级协调的剧本，并嵌入防御性自动化以管理规模和复杂性。

支柱 3

供应商风险现已成为“第一方”和系统性风险

印度 BFSI 的供应商生态系统异常集中。少数几家供应商支撑着各种数字旅程——例如，UPI 和支付、聚合网络、共享核心银行平台、大型 LOS 平台以及第三方 KYC 和 AML 提供商。单一故障现在会同时导致数十家机构瘫痪。

2025 年 8 月，一家领先的销售互动平台发生入侵，通过单一 AI 集成在十天内波及 700 多家组织，这展示了新的攻击模式。过去一年中，95% 的印度顶级金融机构与第三方入侵有关联¹。

7/8

印度监管的跟进速度已快于大多数其他地区。印度储备银行（RBI）2025 年针对非银行金融公司（NBFC）的外包指引要求，供应商必须达到与银行相同的韧性标准。

仅靠监管本身无法创造同步性。大多数印度 BFSI 机构仍将其视为年度准入流程，在采购时进行风险评估，然后在六到十二个月后复查，期间对发生的变化几乎一无所知。

所需的转变是从年度评估转向持续、基于风险等级的动态编排。

第三方已不再处于企业边界之外。他们是网络运营模式的一部分，必须作为业务风险的延伸来治理。

实现第三方同步性的关键行动

- 构建实时关键供应商仪表盘和依赖关系图谱，显示哪些供应商故障会导致业务线中断、客户旅程受阻、控制缺口、安全事件、分包商（\$4^{th}\$ 方）情况以及退出就绪状态。
- 利用威胁情报、外部暴露信号和修复跟踪，以持续监控取代年度供应商评估。
- 重写关键供应商合同，纳入补丁服务水平协议（SLA）、违规通知时限、审计权、分包商审批、日志支持及联合恢复测试。
- 与关键供应商开展联合故障模拟，涵盖勒索软件、云服务中断、API 入侵、数据泄露和支付中断等场景。

支柱 4

人的攻击面：银行内外

在印度 BFSI 领域，员工和客户如今正受到相同威胁行为者、相同 AI 工具和相同攻击手法的针对。增长最快的网络风险，是柜台两侧的人类行为与旨在管理这些行为的控制措施之间的差距。

在银行内部，影子 AI 在十二个月内增长了两倍：2025 年有 15% 的员工使用企业 AI 工具；如今这一比例达到 45%^{\$^{1}\$}。在银行外部，相同的 AI 工具正被武器化用于攻击客户。印度储备银行（RBI）2023-24 年度报告记录了 36,075 起案件，欺诈损失达 13,000 亿卢比，其中约 40% 与数字或网络相关^{\$^{2}\$}。

大多数印度银行将内部和外部作为独立的项目进行防御，内部风险由安全和人力资源部门负责，客户欺诈由分支机构和客户体验部门负责。

威胁行为者并不区分这些。使员工能够向公共大语言模型（LLM）泄露数据的相同生成式AI工具，也使欺诈者能够冒充客户经理来欺骗同一位客户。

攻击者看到的是一个目标。你的组织架构图看到的是两个团队。这个差距就是脆弱性。

实现人类同步性的关键行动

- 设立跨人力资源、法务、合规、IT和安全部门的内部风险小组，对疏忽、被入侵和恶意的员工行为进行分类处理。
- 整合网络、欺诈和客户运营，以检测AI辅助的冒充、钱骡账户、远程访问诈骗和社会工程模式。
- 在客户面临高风险交易时刻，提供实时旅程警告、一键冻结和报告选项，以及通俗易懂的指导。
- 建立跨员工和客户的统一人类风险控制视图，关联访问、数据、设备和交易信号，以早期检测内部滥用、冒充、钱骡活动、远程访问诈骗和异常行为。
- 在员工和客户中培养高级网络安全意识和AI素养，以避免因人类行为带来的风险；随着AI应用的普及，将AI代理视为延伸的人类和高风险向量。

支柱 5

集体防御优于个体防御

网络安全是少数几个竞争对手会共享信息的领域之一，因为威胁行为者并不在乎钓鱼邮件上印的是哪家银行的标志。

印度BFSI拥有基础设施。大多数银行被动地使用它们。印度计算机应急响应小组（CERT-In）的设立是为了协调行业事件响应和情报共享。

所缺乏的是持续、积极的参与。大多数银行只消费情报而不贡献情报，并且大多数机构将行业演练视为合规事件而非战略能力测试。

攻击者以协同经济的方式运作：暗网市场、漏洞即服务产品、共享基础设施、通用攻击手法。相比之下，防御者仍然各自为战。

集体防御的经济性令人信服：单一银行的情报可能只能捕捉到第二次攻击，而共享的行业视角则能捕捉到第一次攻击。

最薄弱的环节最易成为目标——联合响应架构和机制对于“中等规模的印度BFSI机构”将是一项重要的防御举措，这些机构可能因攻击遭受重大损失，但其防御投资和成熟度仍落后于顶尖同行。

攻击者共享基础设施、攻击手法和情报。防御者仍在相互竞争。这种不对称性正是攻击方获胜的原因。

实现生态系统同步性的关键行动

- 创建一个威胁情报小组，通过IB-CART、FS-ISAC、CERT-In及相关监管机构，既消费也贡献情报。
- 将生态系统贡献设为董事会关键绩效指标（KPI），例如每季度提交的入侵指标（IOC）、在规定窗口内披露的事件、完成的跨行业演练。
- 与银行、保险公司、支付机构、云服务商、关键供应商、监管机构和执法部门定期开展行业或联盟网络演练。
- 针对支付中断、通用供应商入侵、恶意应用、凭证泄露和钱骡网络等行业级场景，构建统一的报告框架和共享行动手册。

行动议程 I 行业领导者的前进之路 (I/II)

首席执行官与董事会

- 设立由CEO主持的网络韧性委员会，并明确指定CXO的决策权
- 强制要求每年由CEO主导的网络压力测试，并附带董事会跟踪的修复行动
- 通过避免的业务损失来衡量网络绩效，取代控制覆盖率指标
- 批准一个多年期计划，以达到网络支出占收入1.4%-1.6%的基准
- 每季度审查供应商集中度风险

首席信息官、首席技术官与首席数字官

- 使用量化的网络风险评估来把关主要的数字产品发布（如UPI、AA、数字借贷）
- 在身份、网络、终端和应用层面采用零信任架构
- 根据业务关键风险暴露程度压缩补丁周期
- 与首席信息安全官共同管理AI部署的准备工作
- 将每个API和共享服务视为受监控和测试的控制点

首席信息安全官

- 将网络风险转化为可量化的财务业务影响
- 将安全嵌入运营模式，而不仅仅是技术堆栈
- 以持续监控和故障模拟取代年度供应商评估
- 将身份风险与欺诈监控整合为企业视图
- 推动组织从被动威胁消费转向主动网络防御贡献

行动议程 I 行业领导者的前进之路 (II/II)

首席风险官与首席财务官

- 针对产品、渠道和客户旅程，定义经董事会批准的网络风险偏好
- 将网络风险提升至企业风险仪表盘，与信用风险和市场风险并列
- 按业务线和场景量化网络风险暴露
- 针对关键供应商进行中断和勒索软件破坏场景的压力测试
- \- 将网络投资、保险及生态系统暴露度与量化风险结果挂钩

业务、运营与法律

- \- 为每个业务单元分配量化的网络损失容忍度
- \- 将网络审查嵌入所有产品及业务审批流程
- \- 将内部风险、欺诈及员工意识整合为统一的人力风险计划
- \- 围绕意识与实时欺诈警报构建客户信任计划
- \- 在法律、运营及业务团队间就事件响应问责制达成一致

人工智能时代的网络安全

作者

董事总经理兼合伙人
合伙人

Anand Raman

Vijay Pasupathinathan
负责人

印度数据安全委员会

洞察与研究负责人
Priya Sharma 高级助理，战略与洞察部

致谢

我们衷心感谢BCG及DSCI团队在本报告撰写过程中提供的宝贵贡献、协作与支持。同时感谢参与调研及接受面对面访谈的首席信息安全官与首席高管们。他们在内容开发、分析、营销、编辑审核及制作等环节的专业知识、指导、研究支持与努力，对本报告的最终完成起到了关键作用。

研究与分析支持
编辑与法律审核
董事总经理兼高级合伙人，BCG
设计与制作
网络与数字风险高级总监，BCG Vantage
总监，BCG
创意经理，
高级经理，
董事总经理兼 高级合伙人，BCG
营销传播副总监 印度数据安全委员会
高级设计师，
经理，BCG Vantage
高级法律顾问，BCG
董事总经理兼 合伙人，BCG
高级设计师，BCG设计工作室
团队负责人 – 营销，BCG
Platinion董事总经理，BCG
设计师，
亚太区执行编辑，BCG
设计师，

营销管理培训生， BCG

本报告中的图片均由AI生成